

Cyber Threat Intelligence

Executive Briefing

Report Date: July 06, 2026

Generated: 2026-07-06 15:47 UTC | Classification: TLP:AMBER

Prepared by: Auto-CTI Autonomous Threat Intelligence Pipeline

1. Risk Statistics Summary

Critical	High	Medium	Low	Total
3	11	5	1	20

2. Executive Summary

As of July 06, 2026, the security operations center has concluded an analysis of 20 identified vulnerabilities, comprised of 3 Critical, 11 High, 5 Medium, and 1 Low severity findings. This current threat landscape represents an elevated organizational risk posture, characterized by vulnerabilities that frequently facilitate unauthorized system access and arbitrary code execution. The primary concern is CVE-2026-9559, Mautic Campaign Import Path Traversal, which requires immediate remediation due to its potential for unrestricted file system access and significant compromise of the application environment. Consequently, we have adopted an aggressive patching posture, requiring the immediate suspension of affected service modules where patches are not yet verifiable. Failure to address these exposures systematically will likely result in increased susceptibility to advanced exploitation attempts against our core digital infrastructure.

3. Critical Action List

- CVE-2026-9559: Immediate isolation of Mautic Campaign modules and deployment of emergency hotfix within 24 hours.
- CVE-2026-9558: Immediate implementation of strict input validation policies for Theme Templates within 24 hours.
- CVE-2026-52830: Remediation of the fast-mcp-telegram bearer token validation logic must be completed within 48 hours.
- CVE-2026-53811: Patch the OpenClaw Matrix binding configuration to enforce immutable identity validation within 72 hours.
- CVE-2026-53806: Review and sanitize all POSIX shell execution arguments in OpenClaw components within 72 hours.

4. Quick Reference: All Identified Vulnerabilities

CVE ID	Finding Name	CVSS	Severity	Urgency	CWE
--------	--------------	------	----------	---------	-----

CVE-2026-9559	Mautic Campaign Import Path Trave...	9.9	Critical	89/100	CWE-22
CVE-2026-9558	Mautic Server-Side Template Injec...	9.9	Critical	89/100	CWE-1336
CVE-2026-52830	fast-mcp-telegram Bearer Token Pa...	9.4	Critical	85/100	CWE-22
CVE-2026-53811	OpenClaw Matrix Mutable Display N...	8.8	High	79/100	CWE-290
CVE-2026-53806	OpenClaw POSIX Shell Options Conf...	8.8	High	79/100	CWE-367
CVE-2026-50194	Steeltoe Management Port Isolatio...	8.2	High	74/100	CWE-288
CVE-2026-2092	Keycloak SAML Assertion Validatio...	7.7	High	69/100	CWE-1287
CVE-2026-50200	Steeltoe Env Sanitizer Leaks DB P...	7.5	High	68/100	CWE-200
CVE-2026-50196	Steeltoe Eureka Registry Poisoning	7.5	High	68/100	CWE-20
CVE-2026-9809	Mautic Stored XSS in Projects Com...	7.6	High	68/100	CWE-79
CVE-2026-52726	Dulwich Submodule Path Traversal ...	7.5	High	68/100	CWE-22
CVE-2026-53816	OpenClaw Paired Node Exec Event F...	7.2	High	65/100	CWE-284
CVE-2026-9808	Mautic API v2 Authorization Bypass	7.1	High	64/100	CWE-863
CVE-2026-4776	Mautic API SQL Injection in Conta...	7.1	High	64/100	CWE-89
CVE-2026-50201	Steeltoe Actuator Privilege Escal...	6.5	Medium	59/100	CWE-269
CVE-2026-9557	Mautic Focus Component SSRF Vulne...	6.4	Medium	58/100	CWE-918
CVE-2026-50202	Steeltoe JWKS Cache Invalidation ...	5.9	Medium	53/100	CWE-668
CVE-2026-9811	Mautic Stored XSS in Project Opti...	5.4	Medium	49/100	CWE-79
CVE-2026-50267	Steeltoe TLS Private Key Exposure	4.7	Medium	42/100	CWE-312
CVE-2026-50268	Steeltoe OAEP Padding Information...	1.9	Low	12/100	CWE-256

5. Detailed Vulnerability Findings

CVE-2026-9559

Finding: Mautic Campaign Import Path Traversal

CVSS v3.1 Score: 9.9 | Severity: Critical | Urgency Score: 89/100 | CWE: CWE-22

Score Provenance: CNA Official

MITRE ATT&CK: T1203, T1552.001, T1070.004

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	Low
Scope	Changed
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

Mautic is vulnerable to a Path Traversal vulnerability through its Campaign Import functionality. The root cause is insufficient sanitization of file paths provided during the import process, allowing directory traversal sequences to manipulate file locations on the server. An authenticated user with low privileges can exploit this to achieve critical

impact, including high confidentiality, integrity, and availability, with a scope change.

Proof of Concept (PoC):

An authenticated user with low privileges prepares a malicious campaign import file for Mautic. The attacker crafts the import file (e.g., a ZIP archive) to contain entries with path traversal sequences (e.g., `../../../../`) within the filenames, targeting arbitrary locations outside the designated upload directory. When the Mautic Campaign Import function processes this file, it fails to sanitize the provided paths, extracting the malicious files to arbitrary locations on the server. This results in arbitrary file write capabilities, potentially leading to remote code execution, configuration file modification, or full system compromise.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-9559>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-9559>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-9559>

CVE-2026-9558

Finding: Mautic Server-Side Template Injection

CVSS v3.1 Score: 9.9 | Severity: Critical | Urgency Score: 89/100 | CWE: CWE-1336

Score Provenance: CNA Official
MITRE ATT&CK: T1506, T1059

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Attack Vector	Network	Attack Complexity	Low
Privileges Required	Low	User Interaction	None
Scope	Changed	Confidentiality Impact	High
Integrity Impact	High	Availability Impact	High

Description:

Mautic suffers from a Server-Side Template Injection (SSTI) vulnerability within its Theme Templates functionality. The root cause is the improper handling of user-supplied input that is directly embedded into server-side templates without adequate sanitization, allowing template engine syntax to be executed. An authenticated user with low privileges can exploit this to achieve critical impact, including high confidentiality, integrity, and availability, with a scope change.

Proof of Concept (PoC):

An authenticated user with low privileges navigates to the Theme Templates editor within Mautic and attempts to modify an existing template or create a new one. The attacker injects server-side template engine syntax (e.g., `{{ 7*7 }}` or `{{ system('id') }}`) into a template field. When the Mautic application processes and renders this template on the server, the injected syntax is evaluated. This results in arbitrary code execution on the server, enabling the attacker to fully compromise the Mautic instance and potentially the underlying host system.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-9558>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-9558>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-9558>

CVE-2026-52830

Finding: fast-mcp-telegram Bearer Token Path Traversal

CVSS v3.1 Score: 9.4 | Severity: Critical | Urgency Score: 85/100 | CWE: CWE-22

Score Provenance: CNA Official
MITRE ATT&CK: T1203, T1552.001

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:L

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	Low

Description:

The `fast-mcp-telegram` component is vulnerable to a bearer token path traversal bypass, allowing circumvention of Telegram session protection. This vulnerability stems from insufficient sanitization of input paths, which permits directory traversal sequences (`.../`) to manipulate file paths in security-sensitive operations. An unauthenticated remote attacker can exploit this to achieve high confidentiality and integrity, and low availability, without requiring user interaction.

Proof of Concept (PoC):

An unauthenticated remote attacker sends a specially crafted request to the `fast-mcp-telegram` service's session handling endpoint. The attacker includes path traversal sequences such as `..../` within the bearer token or an associated parameter intended to specify file paths. The service processes the request without adequately sanitizing the path input, allowing access to directories outside the intended scope. This results in the attacker potentially accessing or manipulating sensitive session data or other system files, leading to unauthorized account access and data compromise.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-52830>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-52830>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-52830>

CVE-2026-53811

Finding: OpenClaw Matrix Mutable Display Name Binding

CVSS v3.1 Score: 8.8 | Severity: High | Urgency Score: 79/100 | CWE: CWE-290

Score Provenance: CNA Official
MITRE ATT&CK: T1078, T1078.003, T1594

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	Low
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

OpenClaw's Matrix `allowFrom` functionality could bind to mutable display names, creating a potential security bypass. The root cause is a flaw in the binding mechanism, where trust decisions are made based on easily changeable attributes instead of immutable identifiers. This enables an authenticated user with low privileges to achieve high confidentiality, integrity, and availability impacts by spoofing trusted identities.

Proof of Concept (PoC):

An authenticated user with low privileges, controlling an OpenClaw Matrix client, attempts to interact with services protected by `allowFrom` policies. The attacker modifies their Matrix display name to mimic a trusted entity or service. The `allowFrom` mechanism, when evaluating access, incorrectly relies on the mutable display name for authorization. This results in the attacker bypassing `allowFrom` restrictions, gaining unauthorized access to sensitive functionalities or

data, leading to significant confidentiality, integrity, and availability impacts.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-53811>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-53811>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-53811>

CVE-2026-53806

Finding: OpenClaw POSIX Shell Options Confusion

CVSS v3.1 Score: 8.8 | Severity: High | Urgency Score: 79/100 | CWE: CWE-367

Score Provenance: CNA Official
MITRE ATT&CK: T1059.004, T1078, T1546

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	Low
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

OpenClaw is vulnerable to a security flaw where combined POSIX shell options could confuse `exec` revalidation, leading to a bypass of security checks. The root cause is an intricate interaction between various shell options that alters execution flow in an unexpected manner, undermining the revalidation logic. An authenticated user with low privileges can exploit this to achieve high confidentiality, integrity, and availability impacts by executing unauthorized commands.

Proof of Concept (PoC):

An authenticated user with low privileges crafts an `exec` command within OpenClaw, carefully combining specific POSIX shell options in an unconventional manner. The attacker submits this crafted command for execution, aiming to exploit the revalidation confusion. The OpenClaw `exec` revalidation mechanism, when encountering this particular combination of shell options, misinterprets the intended execution context or security boundaries. This results in the execution of the attacker's command with elevated privileges or in an unintended context, leading to unauthorized data access, system modification, or denial of service.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-53806>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-53806>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-53806>

CVE-2026-50194

Finding: Steeltoe Management Port Isolation Bypass

CVSS v3.1 Score: 8.2 | Severity: High | Urgency Score: 74/100 | CWE: CWE-288

Score Provenance: CNA Official
MITRE ATT&CK: T1078, T1594

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High

Integrity Impact

Low

Availability Impact

None

Description:

Steeltoe is vulnerable to a management-port isolation bypass via spoofed `Host` headers, allowing unauthorized access to restricted endpoints. The root cause is improper validation of the `Host` header, which leads to incorrect routing decisions that bypass network-level access controls designed for management interfaces. An unauthenticated remote attacker can exploit this to achieve high confidentiality and low integrity by accessing restricted management functions.

Proof of Concept (PoC):

An unauthenticated remote attacker sends an HTTP request to the main application port of a Steeltoe application, which is typically accessible externally. The attacker crafts the HTTP request to include a spoofed `Host` header that points to the internal management port's hostname or IP address. The application's internal routing mechanism, failing to adequately validate the `Host` header against allowed origins or the intended port, incorrectly directs the request to the management endpoint. This allows the attacker to access sensitive management actuators (e.g., `/actuator/env`, `/actuator/configprops`) that should only be available via the isolated management port, leading to high confidentiality exposure.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-50194>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-50194>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-50194>

CVE-2026-2092**Finding: Keycloak SAML Assertion Validation Bypass**

CVSS v3.1 Score: 7.7 | Severity: High | Urgency Score: 69/100 | CWE: CWE-1287

Score Provenance: CNA Official

MITRE ATT&CK: T1078.004, T1537

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:C/C:H/I:L/A:L

Attack Vector	Network
Privileges Required	Low
Scope	Changed
Integrity Impact	Low

Attack Complexity	High
User Interaction	None
Confidentiality Impact	High
Availability Impact	Low

Description:

Keycloak suffers from improper validation of encrypted SAML assertions, leading to an unauthorized access vulnerability. The root cause is insufficient verification of SAML assertion integrity and authenticity, allowing a malicious actor to craft and present a manipulated assertion. This enables an authenticated user with low privileges to bypass intended access controls and achieve high confidentiality, low integrity, and low availability impact with a scope change.

Proof of Concept (PoC):

An authenticated user with low privileges identifies the SAML authentication flow within Keycloak. The attacker intercepts and modifies an encrypted SAML assertion, specifically altering attributes to elevate privileges or access restricted resources without detection. Keycloak's assertion validation fails to correctly verify the integrity or authenticity of the modified assertion, accepting it as legitimate. This allows the attacker to gain unauthorized access to resources with elevated privileges, impacting confidentiality and integrity.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-2092>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-2092>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-2092>

CVE-2026-50200

Finding: Steeltoe Env Sanitizer Leaks DB Passwords

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-200

Score Provenance: CNA Official

MITRE ATT&CK: T1552.001, T1083

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

Steeltoe's environment variable sanitizer fails to properly redact connection strings, leading to the leakage of embedded database passwords. The root cause is an incomplete or ineffective sanitization routine that does not recognize or correctly mask sensitive information within database connection string patterns. An unauthenticated remote attacker can exploit this to gain high confidentiality, by potentially accessing database credentials without requiring any user interaction.

Proof of Concept (PoC):

An unauthenticated remote attacker accesses an endpoint that exposes environment variables or configuration details, such as an `/actuator/env` endpoint if inadvertently exposed. The attacker queries this endpoint, expecting sensitive information to be redacted by the sanitizer. However, the Steeltoe env sanitizer fails to properly identify and mask database connection strings containing credentials. This results in the attacker obtaining cleartext database passwords, which can then be used for direct database access and further data exfiltration or manipulation.`

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-50200>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-50200>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-50200>

CVE-2026-50196

Finding: Steeltoe Eureka Registry Poisoning

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-20

Score Provenance: CNA Official

MITRE ATT&CK: T1499, T1498

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	High

Description:

Steeltoe.Discovery.Eureka is vulnerable to a denial-of-service condition where an unrecognized ``DataCenterInfo.Name`` poisons the entire registry fetch operation. The root cause is improper handling of malformed or unexpected data in the Eureka registry response, leading to a parsing failure that prevents the application from processing any registry updates.

An unauthenticated remote attacker can exploit this to achieve high availability impact, effectively disrupting service discovery.

Proof of Concept (PoC):

An unauthenticated remote attacker targets a vulnerable Steeltoe.Discovery.Eureka client application configured to fetch from a Eureka server. The attacker intercepts or crafts a malicious Eureka registry response containing an `instance` entry with an unrecognized or malformed `DataCenterInfo.Name` attribute. When the Steeltoe client attempts to parse this response, the malformed data causes a critical deserialization or validation error, leading to a complete failure of the registry fetch. This prevents the application from discovering services, effectively causing a denial of service for the client and its dependent services.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-50196>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-50196>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-50196>

CVE-2026-9809

Finding: Mautic Stored XSS in Projects Component

CVSS v3.1 Score: 7.6 | Severity: High | Urgency Score: 68/100 | CWE: CWE-79

Score Provenance: CNA Official

MITRE ATT&CK: T1059.007, T1204.001

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:R/S:C/C:L/I:H/A:N

Attack Vector	Network
Privileges Required	Low
Scope	Changed
Integrity Impact	High

Attack Complexity	Low
User Interaction	Required
Confidentiality Impact	Low
Availability Impact	None

Description:

Mautic is affected by a Stored Cross-Site Scripting (XSS) vulnerability within its Projects Component. The root cause involves inadequate input sanitization and output encoding of user-controlled data that is stored and later reflected in the application's web interface. This allows an authenticated user with low privileges to inject malicious scripts, leading to low confidentiality and high integrity impact on other users with required user interaction.

Proof of Concept (PoC):

An authenticated user with low privileges accesses the Mautic Projects Component and creates or modifies a project entry. The attacker injects a persistent XSS payload, such as a JavaScript code snippet designed to deface the page or steal cookies, into a user-editable field (e.g., project name or description). The application stores this malicious content and, when any user subsequently views the affected project, the stored script is executed by their browser due to improper output encoding. This leads to arbitrary client-side script execution, enabling session hijacking, data exfiltration, or UI manipulation.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-9809>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-9809>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-9809>

CVE-2026-52726

Finding: Dulwich Submodule Path Traversal RCE

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-22

Score Provenance: CNA Official

MITRE ATT&CK: T1203, T1059

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	High

Description:

Dulwich's ``porcelain.submodule_update`` and ``porcelain.clone(recurse_submodules=True)`` functions are vulnerable to a submodule path traversal that can lead to Remote Code Execution (RCE). The root cause is inadequate sanitization of submodule paths, allowing an attacker to place a malicious ``.git/hooks`` payload in an arbitrary location during submodule operations. An unauthenticated remote attacker can exploit this to achieve high availability impact through arbitrary code execution.

Proof of Concept (PoC):

An unauthenticated remote attacker creates a malicious Git repository containing a submodule with a path traversal sequence (e.g., ``.git/hooks/post-checkout``) and embeds an executable payload within it. A user or automated system cloning or updating this repository using Dulwich's ``porcelain.clone(recurse_submodules=True)`` or ``porcelain.submodule_update`` functions will trigger the vulnerability. Dulwich processes the submodule path without proper sanitization, dropping the attacker's payload into a critical Git hook directory. This results in remote code execution on the system when subsequent Git operations trigger the hook, leading to full system compromise and high availability impact.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-52726>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-52726>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-52726>

CVE-2026-53816

Finding: OpenClaw Paired Node Exec Event Forgery

CVSS v3.1 Score: 7.2 | Severity: High | Urgency Score: 65/100 | CWE: CWE-284

Score Provenance: CNA Official

MITRE ATT&CK: T1078, T1059, T1546

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	High
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

OpenClaw's paired nodes could forge ``exec`` lifecycle events without proper ``system.run`` provenance, enabling unauthorized command execution. The root cause is a deficiency in the provenance verification for ``exec`` lifecycle events, allowing a malicious paired node to inject unauthorized commands. An authenticated user with high privileges can exploit this to achieve high confidentiality, integrity, and availability impacts.

Proof of Concept (PoC):

An authenticated user with high privileges establishes a paired node relationship within the OpenClaw environment. The attacker then crafts and sends a malicious `exec` lifecycle event from their paired node, intentionally omitting or falsifying the `system.run` provenance information typically required for such events. The OpenClaw system processes this event without adequately verifying its provenance, treating it as legitimate. This results in the execution of arbitrary commands or scripts on the target system with the privileges of the affected service, leading to full compromise of confidentiality, integrity, and availability.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-53816>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-53816>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-53816>

CVE-2026-9808

Finding: Mautic API v2 Authorization Bypass

CVSS v3.1 Score: 7.1 | Severity: High | Urgency Score: 64/100 | CWE: CWE-863

Score Provenance: CNA Official
MITRE ATT&CK: T1078, T1078.003

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:L/A:N

Attack Vector	Network
Privileges Required	Low
Scope	Unchanged
Integrity Impact	Low

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

Mautic contains an Authorization Bypass vulnerability affecting its API v2 Endpoints, allowing unauthorized access to restricted functionalities. The root cause is a flaw in the API's access control logic, which fails to properly enforce privilege separation for certain API operations. This enables an authenticated user with low privileges to perform actions or access data reserved for higher-privileged accounts, resulting in high confidentiality and low integrity impact.

Proof of Concept (PoC):

An authenticated user with low privileges accesses the Mautic API v2, attempting to interact with endpoints normally restricted to administrators or higher-privileged users. The attacker sends a direct API request to a protected endpoint (e.g., `/api/v2/users/{id}`, `/api/v2/config`) with their low-privileged authentication token. The API's authorization mechanism fails to correctly verify that the requesting user has the necessary permissions for the targeted operation. This allows the attacker to read, modify, or delete data beyond their authorized scope, leading to an authorization bypass and data exposure.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-9808>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-9808>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-9808>

CVE-2026-4776

Finding: Mautic API SQL Injection in Contact Filtering

CVSS v3.1 Score: 7.1 | Severity: High | Urgency Score: 64/100 | CWE: CWE-89

Score Provenance: CNA Official
MITRE ATT&CK: T1505.001, T1059.008

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:L

Attack Vector	Network
Privileges Required	Low
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	Low

Description:

Mautic contains a SQL Injection vulnerability within its API Contact Filtering functionality, allowing for direct database manipulation. The root cause is improper sanitization of user-supplied input parameters within the API's filtering logic, leading to the direct inclusion of malicious SQL queries. An authenticated user with low privileges can exploit this to achieve high confidentiality and low availability impact.

Proof of Concept (PoC):

An authenticated user with low privileges sends an API request to the Mautic contacts endpoint, attempting to filter contacts using a maliciously crafted parameter. The attacker injects SQL commands (e.g., `` OR 1=1 --`) into the filtering parameter in the API request. The application's backend database query, when constructed, directly incorporates this unsanitized input into the SQL statement, leading to its execution. This results in the attacker being able to extract arbitrary data from the database, bypassing authorization controls, or causing a denial of service by corrupting data.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-4776>Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-4776>Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-4776>**CVE-2026-50201****Finding: Steeltoe Actuator Privilege Escalation****CVSS v3.1 Score: 6.5 | Severity: Medium | Urgency Score: 59/100 | CWE: CWE-269**

Score Provenance: CNA Official

MITRE ATT&CK: T1078, T1552

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Network
Privileges Required	Low
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

Steeltoe's sensitive actuators (e.g., heapdump, env) only require 'Restricted' permission for access, which is often insufficient for proper security segmentation. The root cause is an inadequate authorization model where highly sensitive administrative functions are protected by a permission level that is too broad, allowing unintended access. An authenticated user with low privileges can exploit this to achieve high confidentiality impact by accessing diagnostic data.

Proof of Concept (PoC):

An authenticated user with low privileges attempts to access sensitive Steeltoe actuator endpoints such as ``/actuator/heapdump`` or ``/actuator/env``. The attacker makes a direct HTTP request to these endpoints, expecting authorization to fail due to insufficient permissions. However, the application's authorization check for 'Restricted'

permissions incorrectly grants access to these sensitive functions. This allows the attacker to download heap dumps or environment variables, potentially revealing sensitive configuration details, API keys, or memory contents, leading to high confidentiality compromise.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-50201>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-50201>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-50201>

CVE-2026-9557

Finding: Mautic Focus Component SSRF Vulnerability

CVSS v3.1 Score: 6.4 | Severity: Medium | Urgency Score: 58/100 | CWE: CWE-918

Score Provenance: CNA Official
MITRE ATT&CK: T1595.002, T1090

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:L/I:L/A:N

Attack Vector	Network	Attack Complexity	Low
Privileges Required	Low	User Interaction	None
Scope	Changed	Confidentiality Impact	Low
Integrity Impact	Low	Availability Impact	None

Description:

The Mautic Focus component is vulnerable to Server-Side Request Forgery (SSRF), allowing the application to be coerced into making arbitrary network requests. The root cause is inadequate validation of user-supplied URLs or domain names within the Focus component's configuration. An authenticated user with low privileges can exploit this to achieve low confidentiality and integrity impact, allowing for internal network reconnaissance or interaction with intranet services.

Proof of Concept (PoC):

An authenticated user with low privileges accesses the Mautic Focus component configuration interface, which allows specifying external URLs or callback endpoints. The attacker inputs a crafted URL pointing to an internal network resource (e.g., `http://169.254.169.254/latest/meta-data/`) or an intranet service. When the Mautic application processes this configuration, it initiates a request to the attacker-supplied internal URL without proper validation or filtering. This results in the server performing requests to arbitrary internal or external targets, potentially allowing for port scanning, accessing cloud metadata, or interacting with internal services, leading to internal network reconnaissance and limited data exposure.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-9557>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-9557>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-9557>

CVE-2026-50202

Finding: Steeltoe JWKS Cache Invalidation Vulnerability

CVSS v3.1 Score: 5.9 | Severity: Medium | Urgency Score: 53/100 | CWE: CWE-668

Score Provenance: CNA Official
MITRE ATT&CK: T1537, T1078

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:H/PR:H/UI:N/S:U/C:H/I:H/A:N

Attack Vector	Network
Privileges Required	High
Scope	Unchanged
Integrity Impact	High

Attack Complexity	High
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

Steeltoe's static JWKS (JSON Web Key Set) cache is shared across different authentication schemes and lacks proper invalidation mechanisms. The root cause is an architectural flaw where cryptographic key material is cached globally without scheme-specific isolation or a means to force a refresh when keys are updated. This enables an authenticated user with high privileges to potentially gain high confidentiality and integrity impact by leveraging stale or shared keys.

Proof of Concept (PoC):

An authenticated user with high privileges manipulates the JWKS configuration or observes a key rotation event in a multi-scheme Steeltoe deployment. The attacker attempts to authenticate using a token signed with a revoked or outdated key that might still be present in the shared, invalidated cache. The application, relying on the stale cache, validates the token incorrectly, granting unauthorized access. This allows the attacker to maintain access with expired credentials or impersonate other users if keys from different schemes are mixed, leading to confidentiality and integrity compromise.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-50202>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-50202>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-50202>

CVE-2026-9811**Finding: Mautic Stored XSS in Project Option Selector**

CVSS v3.1 Score: 5.4 | Severity: Medium | Urgency Score: 49/100 | CWE: CWE-79

Score Provenance: CNA Official

MITRE ATT&CK: T1059.007, T1204.001

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:R/S:C/C:L/I:L/A:N

Attack Vector	Network
Privileges Required	Low
Scope	Changed
Integrity Impact	Low

Attack Complexity	Low
User Interaction	Required
Confidentiality Impact	Low
Availability Impact	None

Description:

Mautic contains a Stored Cross-Site Scripting (XSS) vulnerability within the Project Option Selector component. The root cause is insufficient input sanitization and output encoding of user-supplied data that is subsequently rendered in a web page. This allows an authenticated user with low privileges to inject malicious scripts into the application, resulting in low confidentiality and integrity impact on other users.

Proof of Concept (PoC):

An authenticated user with low privileges navigates to the Project Option Selector interface within Mautic and attempts to create or edit a project. The attacker inputs a crafted string containing malicious JavaScript (e.g., `

leading to session hijacking or defacement of the application interface.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-9811>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-9811>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-9811>

CVE-2026-50267

Finding: Steeltoe TLS Private Key Exposure

CVSS v3.1 Score: 4.7 | Severity: Medium | Urgency Score: 42/100 | CWE: CWE-312

Score Provenance: CNA Official
MITRE ATT&CK: T1552.004, T1552.001

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:L/AC:H/PR:L/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Local	Attack Complexity	High
Privileges Required	Low	User Interaction	None
Scope	Unchanged	Confidentiality Impact	High
Integrity Impact	None	Availability Impact	None

Description:

Steeltoe is vulnerable to TLS private key exposure due to insecure file handling practices for temporary keys. The root cause lies in the application writing TLS private keys to the `/tmp` directory with default, permissive permissions, and failing to delete them after use. This enables a local user with low privileges to access highly sensitive cryptographic material, resulting in high confidentiality impact.

Proof of Concept (PoC):

A local user with low privileges observes a Steeltoe application generating TLS private keys. The attacker then checks the `/tmp` directory for newly created files with typical private key extensions or content patterns. Due to default permissive file permissions and the lack of timely deletion, the private keys remain accessible to the attacker. This allows the attacker to steal the TLS private keys, compromising the confidentiality of encrypted communications and potentially enabling man-in-the-middle attacks.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-50267>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-50267>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-50267>

CVE-2026-50268

Finding: Steeltoe OAEP Padding Information Disclosure

CVSS v3.1 Score: 1.9 | Severity: Low | Urgency Score: 12/100 | CWE: CWE-256

Score Provenance: CNA Official
MITRE ATT&CK: T1552.001

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:L/AC:H/PR:H/UI:N/S:U/C:L/I:N/A:N

Attack Vector	Local	Attack Complexity	High
Privileges Required	High	User Interaction	None
Scope	Unchanged	Confidentiality Impact	Low
Integrity Impact	None	Availability Impact	None

Description:

Steeltoe's implementation of OAEP (Optimal Asymmetric Encryption Padding) silently selects PKCS#1 v1.5 padding, diverging from expected behavior without explicit indication. The root cause is an implicit default in the cryptographic library's configuration, leading to a weaker padding scheme being used than might be assumed. This enables a local user with high privileges to potentially gain low confidentiality of encrypted data, but only under specific, hard-to-exploit conditions.

Proof of Concept (PoC):

A local user with high privileges observes the cryptographic operations within a Steeltoe application utilizing OAEP. The attacker specifically monitors for signs of PKCS#1 v1.5 padding being used, which can sometimes be distinguished from OAEP through timing side channels or error messages in certain configurations. The application's silent selection of PKCS#1 v1.5 padding, contrary to expectation, may introduce a subtle weakness. This could potentially allow the attacker to gather limited information that might aid in further decryption efforts, albeit with significant complexity.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-50268>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-50268>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-50268>

6. Methodology & Data Sources

This report was generated by the Auto-CTI Autonomous Cyber Threat Intelligence Pipeline, an automated multi-agent system designed to simulate a real-world Security Operations Center (SOC) workflow. The pipeline operates in three sequential stages: (1) the Scout Agent collects the latest CVE disclosures from NVD, the GitHub Advisory Database, and OSV.dev, cross-referencing active threat pulses via AlienVault OTX; (2) the Triage Agent performs structured analysis using the CVSS v3.1 scoring standard, assigns CWE root-cause classifications, maps each vulnerability to relevant MITRE ATT&CK techniques, and computes a composite Urgency Score; (3) the Publisher Agent synthesizes the triaged data into this executive briefing. Every CVSS score is tagged with a Score Provenance label indicating whether it was confirmed against an official database (NVD or CNA record) or estimated by the analysis model when no official score existed. All CVE identifiers, CVSS scores, and CWE mappings are independently verifiable via the references provided in Section 5. References marked 'Fallback Search' indicate the specific CVE record was not found live at NVD or CVE.org at generation time; a source-database search link is provided instead. Severity classification follows the CVSS v3.1 standard: Critical (9.0-10.0), High (7.0-8.9), Medium (4.0-6.9), Low (0.1-3.9).

Primary Data Sources:

- NIST National Vulnerability Database (NVD) -- <https://nvd.nist.gov/>
- GitHub Advisory Database -- <https://github.com/advisories>
- OSV.dev Open Source Vulnerabilities -- <https://osv.dev/>
- CVE Services API (MITRE CNA Records) -- <https://cveawg.mitre.org/>
- OpenCVE -- <https://www.opencve.io/>
- AlienVault Open Threat Exchange (OTX) -- <https://otx.alienvault.com/>
- MITRE ATT&CK Framework -- <https://attack.mitre.org/>
- CVSS v3.1 Specification -- <https://www.first.org/cvss/v3.1/specification-document>
- Common Weakness Enumeration (CWE) -- <https://cwe.mitre.org/>
- CVE Program -- <https://www.cve.org/>